RUNBOOK

A thousand repos leaked secrets this week

Not a hack. Not a model failure. One permission setting.

WHAT HAPPENED

1,122 repos had a secret saved in plain text

Security firm Apiiro scanned public Claude Code settings files

- 2,539 secrets total across 1,994 repositories
- Found in .claude/settings.local.json and chat logs
- One confirmed key was still live when notified

THE MECHANISM

"Don't ask again" writes the secret to disk

This is the actual bug, and it's a UX choice, not an AI mistake

- User approves a command containing a secret once
- Agent saves that exact command as an allow rule
- The secret gets written into a project settings file
- File gets committed and pushed like any other file

THE PART PEOPLE MISS

Claude often commits the leak itself

539 of 1,105 traced repos show Claude co-authoring the commit

- User says "commit my changes", a normal request
- The settings file with the secret ships along with it
- No malicious intent anywhere in the chain

WHY THIS MATTERS

Convenience settings remove per-action judgment

The agent isn't reasoning about risk anymore, it's following a rule

- Blanket approval turns risky writes into routine ones
- No prompt means no human checkpoint before the leak
- Claude Code was the only agent tested that defaults this way

THE LESSON

Agent permissions need the same rigor as API scopes

If you wouldn't give blanket write access to a junior dev, don't give it here

- "Don't ask again" should be scoped, not global
- Treat agent-generated commits like any other PR
- Secrets belong in env vars or a vault, never inline

WHAT TO DO THIS WEEK

Three checks before your next agent session

Anthropic's own team is telling people to do this now

- Turn on secret scanning on your source host
- Audit .claude/settings.local.json in every repo you own
- Review what your agent is allowed to do without asking

TAKEAWAY

The model didn't leak your secrets. Your settings did

Agent reliability is a permissions and workflow problem first

- Autonomy without guardrails just moves the risk around
- Human checkpoints exist for a reason, keep the ones that matter

CTA

Auditing your agent permissions yet?

I build agent workflows with guardrails baked in, not bolted on after a leak

- What's your current approval setup for coding agents?

Lark AI Agency | Paul Charles